



ARKA HEALTH, INC.

RISK ANALYSIS & RISK MANAGEMENT POLICY

Security management process under 45 C.F.R. § 164.308(a)(1) and NIST SP 800-30

ARKA-SEC-002 · Version 1.0 · Confidential — Internal

Document No.	ARKA-SEC-002
Version	1.0
Effective Date	June 10, 2026
Last Reviewed	June 10, 2026
Document Owner	Arri Kanna, Founder & Chief Executive Officer — Privacy & Security Officer
Approved By	Arri Kanna, Founder & Chief Executive Officer
Classification	Confidential — Internal
Review Cycle	Annual, and upon any material change in operations, systems, or law

This document contains confidential and proprietary information of ARKA Health, Inc. (“ARKA”). It is furnished for informational and compliance purposes, may not be reproduced or disclosed to any third party without the prior written consent of ARKA, and must be returned or destroyed upon request. Nothing in this document constitutes legal advice.

1. PURPOSE

This Policy implements the Security Management Process standard, 45 C.F.R. § 164.308(a)(1), by establishing a recurring, documented process to (a) conduct an accurate and thorough assessment of the potential risks and vulnerabilities to the confidentiality, integrity, and availability of ePHI held by ARKA Health, Inc., and (b) implement security measures sufficient to reduce those risks and vulnerabilities to a reasonable and appropriate level.

2. METHODOLOGY

Risk analyses shall follow the methodology of NIST Special Publication 800-30 (Rev. 1), informed by the Office for Civil Rights' *Guidance on Risk Analysis Requirements under the HIPAA Security Rule* and NIST SP 800-66 (Rev. 2). Each analysis shall:

1. define the scope by reference to the current technology asset inventory and network map (ARKA-SEC-001, § 3), such that **all** systems that create, receive, maintain, or transmit ePHI — or that could affect such systems — are included;
2. identify and document reasonably anticipated threats (adversarial, accidental, structural, environmental) and vulnerabilities for each asset class;
3. assess current controls against the ARKA-SEC policy series and applicable vendor attestations (SOC 2 reports of cloud providers);
4. assign likelihood and impact ratings on a five-point scale and compute an inherent and residual risk rating for each threat–vulnerability pair;
5. document risk-treatment decisions — remediate, mitigate, transfer, or accept — with owner and due date for each; acceptance of any risk rated High or Critical requires the written approval of the Chief Executive Officer; and
6. record results in the risk register, which constitutes part of the documentation retained under 45 C.F.R. § 164.316(b).

3. CADENCE AND TRIGGERS

A full risk analysis shall be performed no less than every twelve (12) months, and a targeted re-assessment shall be performed within thirty (30) days of: (a) any material architectural change (new data store, new subprocessor, new module processing ePHI); (b) any Security Incident classified Severity 2 or higher under ARKA-SEC-006; (c) execution of a BAA with materially new data scope; or (d) publication of a final rule materially amending the Security Rule. The initial enterprise risk assessment is documented in ARKA-RDY-001.

4. RISK MANAGEMENT PLAN

The Security Officer shall maintain an annual risk-management plan that sequences remediation by residual risk, assigns owners and budgets, and is approved by the Security & Compliance Committee. Progress shall be reviewed quarterly; items overdue by more than thirty (30) days shall be escalated to the Chief Executive Officer with a written corrective schedule.

5. EVALUATION

In accordance with 45 C.F.R. § 164.308(a)(8), ARKA shall perform a written technical and nontechnical evaluation in response to environmental or operational changes affecting the security of ePHI, and in any event annually, assessing the extent to which the Company's security policies and procedures meet the requirements of Subpart C. The annual evaluation may be satisfied by the combination of the annual risk analysis, penetration-test results, and the readiness assessments maintained under the ARKA-RDY series.

DOCUMENT CONTROL & REVISION HISTORY

Version	Date	Author / Reviewer	Description of Change
0.9	May 22, 2026	A. Kanna (drafting); external review pending	Initial draft circulated for internal review and counsel comment.
1.0	June 10, 2026	A. Kanna, Privacy & Security Officer	Adopted as effective policy of ARKA Health, Inc. by written approval of the undersigned officer.

ADOPTION AND APPROVAL

The undersigned, being the duly designated Privacy Officer and Security Officer of ARKA Health, Inc., hereby adopts this document as an official policy of the Company, effective as of the Effective Date set forth on the cover page hereof. This document shall be reviewed no less frequently than annually and upon any material change to the Company's operations, information systems, or applicable law, and may be amended only in accordance with ARKA-GOV-001 (Information Security & Compliance Program Charter).

ARKA HEALTH, INC.

By: _____

Name: Arri Kanna

Title: Founder & Chief Executive Officer; Privacy & Security Officer

Date: June 10, 2026